

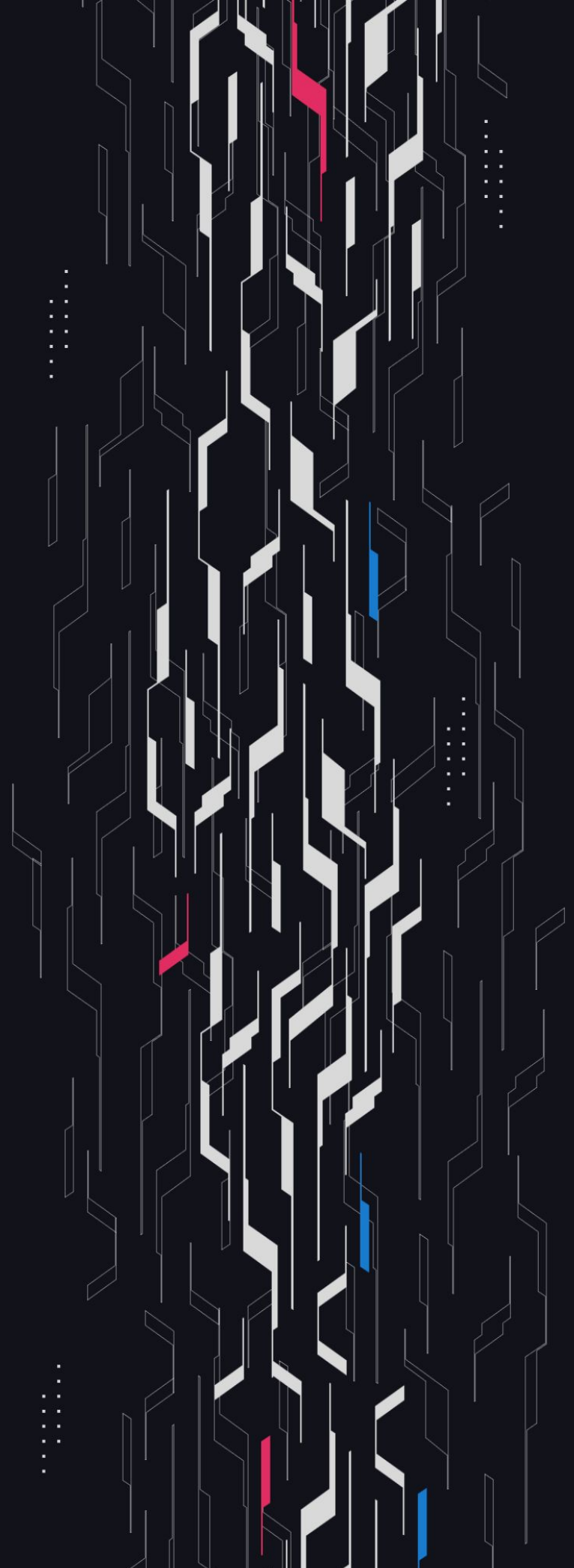
GA GUARDIAN

USDT0

**XAUt BSC
Deployment Review**

Security Assessment

March 23rd, 2026



Summary

Audit Firm Guardian

Prepared By CuriousApple

Client Firm USDT0

Final Report Date March 23, 2026

Audit Summary

USDT0 engaged Guardian to review the security of their XAUt deployment on Binance Smart Chain. On the 18th of March, an auditor reviewed the source code in scope. All findings have been recorded in the following report.

Confidence Ranking

Given the lack of High and Critical issues detected during the main review, Guardian assigns a Confidence Ranking of 5 to the protocol. Guardian advises the protocol to consider periodic review with future changes. For detailed understanding of the Guardian Confidence Ranking, please see the rubric on the following page.

✓ Verify the authenticity of this report on Guardian's GitHub: <https://github.com/guardianaudits>

Guardian Confidence Ranking

Confidence Ranking	Definition and Recommendation	Risk Profile
5: Very High Confidence	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: Code is highly secure at time of audit. Low risk of latent critical issues.	0 High/Critical findings and few Low/Medium severity findings.
4: High Confidence	Code is clean, well-structured, and adheres to best practices. Only 1 Significant issue was uncovered per week. Design patterns are sound, and test coverage is strong. Recommendation: Suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity issues. Varied Low severity findings.
3: Moderate Confidence	Medium-severity and occasional High-severity issues found. Code is functional, but there are concerning areas (e.g., weak modularity, risky patterns). No critical design flaws, though some patterns could lead to issues in edge cases. Recommendation: Address issues thoroughly and consider a targeted follow-up audit depending on code changes.	1-2 High/Critical findings per engagement week.
2: Low Confidence	Code shows frequent emergence of Critical/High vulnerabilities. Audit revealed recurring anti-patterns, weak test coverage, or unclear logic. These characteristics suggest a high likelihood of latent issues. Recommendation: Post-audit development and a second audit cycle are strongly advised.	2-4 High/Critical findings per engagement week. Or additional High/Critical findings uncovered in remediation review which have not been resolved and confirmed by Guardian.
1: Very Low Confidence	Code has systemic issues. Multiple High/Critical findings (≥ 5/week), poor security posture, and design flaws that introduce compounding risks. Safety cannot be assured. Recommendation: Halt deployment and seek a comprehensive re-audit after substantial refactoring.	≥ 5 High/Critical findings and overall systemic flaws.

Table of Contents

Project Information

Project Overview 5

Transactions Reviewed 7

Audit Scope & Methodology 8

Smart Contract Risk Assessment

Findings & Resolutions 10

Addendum

Disclaimer 12

About Guardian 13

Project Overview

Project Summary

Project Name	USDT0
Codebase(s)	https://github.com/Everdawn-Labs/usdt0-oft-contracts https://github.com/LayerZero-Labs/LayerZero-v2
Commit(s)	USDT0-OFT-Contracts: d4f836a8fd9572c4ab53dd677ecabdd90483bd7a
Addresses	Token Proxy: 0x21cAef8A43163Eea865baeE23b9C2E327696A3bf Token Implementation: 0x9151434b16b9763660705744891fa906f660ecc5 Token ProxyAdmin: 0xedaba024be4d87974d5ab11c6dd586963cccb027 OFT Proxy: 0x53C3A64c8942288e12813C1F8457Db45980BcfC2 OFT Implementation: 0xded1660192d4d82e7c0b628ba556861edbb5cada OFT ProxyAdmin: 0x01bff41798a0bcf287b996046ca68b395dbc1071 Safe (Multisig): 0x4dff9b5b0143e642a3f63a5bcf2d1c328e600bf8

Project Overview

Audit Summary

Delivery Date	January 31, 2026
Audit Methodology	Static Analysis, Manual Review, Test Suite, Contract Fuzzing

Vulnerability Summary

Vulnerability Level	Total	Pending	Declined	Acknowledged	Partially Resolved	Resolved
● Critical	0	0	0	0	0	0
● High	0	0	0	0	0	0
● Medium	0	0	0	0	0	0
● Low	1	0	0	1	0	0
● Info	0	0	0	0	0	0

Transactions Reviewed

Chain	Safe address	Nonce range
Ethereum	0x4DFF9b5b0143E642a3F63a5bcf2d1C328e600bf8	139–144

Audit Scope & Methodology

Vulnerability Classifications

Severity	Impact: <i>High</i>	Impact: <i>Medium</i>	Impact: <i>Low</i>
Likelihood: <i>High</i>	● Critical	● High	● Medium
Likelihood: <i>Medium</i>	● High	● Medium	● Low
Likelihood: <i>Low</i>	● Medium	● Low	● Low

Impact

- High** Significant loss of assets in the protocol, significant harm to a group of users, or a core functionality of the protocol is disrupted.
- Medium** A small amount of funds can be lost or ancillary functionality of the protocol is affected. The user or protocol may experience reduced or delayed receipt of intended funds.
- Low** Can lead to any unexpected behavior with some of the protocol's functionalities that is notable but does not meet the criteria for a higher severity.

Likelihood

- High** The attack is possible with reasonable assumptions that mimic on-chain conditions, and the cost of the attack is relatively low compared to the amount gained or the disruption to the protocol.
- Medium** An attack vector that is only possible in uncommon cases or requires a large amount of capital to exercise relative to the amount gained or the disruption to the protocol.
- Low** Unlikely to ever occur in production.

Audit Scope & Methodology

Methodology

Guardian is the ultimate standard for Smart Contract security. An engagement with Guardian entails the following:

- Two competing teams of Guardian security researchers performing an independent review.
- A dedicated fuzzing engineer to construct a comprehensive stateful fuzzing suite for the project.
- An engagement lead security researcher coordinating the 2 teams, performing their own analysis, relaying findings to the client, and orchestrating the testing/verification efforts.

The auditing process pays special attention to the following considerations:

- Testing the smart contracts against both common and uncommon attack vectors.
- Assessing the codebase to ensure compliance with current best practices and industry standards.
- Ensuring contract logic meets the specifications and intentions of the client.
- Cross-referencing contract structure and implementation against similar smart contracts produced by industry leaders.
- Thorough line-by-line manual review of the entire codebase by industry experts.
Comprehensive written tests as a part of a code coverage testing suite.
- Contract fuzzing for increased attack resilience.

Findings & Resolutions

ID	Title	Category	Severity	Status
L-01	Potential DoS via Unexecutable Inbound Message Queue	DoS	Low	Acknowledged

L-01 | Potential DoS Via Unexecutable Inbound Message Queue

Category	Severity	Location	Status
DoS	● Low	https://github.com/LayerZero-Labs/LayerZero-v2	Acknowledged

Description

When an inbound payload is cleared, MessagingChannel._clearPayload lazily advances the inbound nonce by looping over every earlier nonce and checking that each message has at least been inbounded:

```
if (_nonce > currentNonce) {
  unchecked {
    for (uint64 i = currentNonce + 1; i <= _nonce; ++i) {
      if (!_hasPayloadHash(_receiver, _srcEid, _sender, i)) {
        revert Errors.LZ_InvalidNonce(i);
      }
    }
    lazyInboundNonce[_receiver][_srcEid][_sender] = _nonce;
  }
}
```

This design assumes older queued messages will gradually clear and reduce pressure on later ones. That assumption breaks when earlier messages are inbounded but cannot execute. In OApps such as Tether, an attacker can repeatedly send messages that are valid enough to enter the inbound queue but revert on destination execution, for example by targeting blacklisted recipients. Because the messages stay ahead of later nonces, the lazy scan can become increasingly expensive and eventually run out of gas when processing subsequent traffic. This does not permanently brick the channel or directly lose funds because LayerZero provides a skip mechanism for the OApp owner or delegate to advance the nonce manually. Still, it creates a real operational DoS risk that can temporarily block later messages until intervention occurs.

Recommendation

Consider monitoring inbound queues for buildups of unexecutable messages and proactively using skip when a channel begins to accumulate blocked traffic.

Resolution

USDT0: Acknowledged.

Disclaimer

This report is not, nor should be considered, an “endorsement” or “disapproval” of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any “product” or “asset” created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian’s position is that each company and individual are responsible for their own due diligence and continuous security. Guardian’s goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis. Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract’s safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

About Guardian

Founded in 2022 by DeFi experts, Guardian is a leading audit firm in the DeFi smart contract space. With every audit report, Guardian upholds best-in-class security while achieving our mission to relentlessly secure DeFi.

To learn more, visit <https://guardianaudits.com>

To view our audit portfolio, visit <https://github.com/guardianaudits>

To book an audit, message <https://t.me/guardianaudits>